

Microsoft Incident Response Ransomware Approach & Best Practices

Microsoft Learn field guide for ransomware incident response readiness and operations

Condensed, non-verbatim operational guide

Purpose	Quick-reference guide for understanding the Microsoft Incident Response ransomware approach, investigation model, containment priorities, recovery focus, and post-incident best practices.
Primary audience	SecOps analysts, incident responders, security leaders, identity administrators, endpoint administrators, and customer-facing security teams.
Reference source	https://learn.microsoft.com/en-us/security/ransomware/incident-response-playbook-dart-ransomware-approach
Generated	2026-07-03
Use note	This document is a concise field guide based on Microsoft Learn guidance. Use the linked Microsoft Learn article as the authoritative source for the latest details, product references, and Microsoft Incident Response recommendations.

Prepared for: Muataz Awad | Microsoft Security customer-facing readiness

1. Purpose and response mindset

The referenced Microsoft Learn article frames human-operated ransomware as a human criminal problem, not merely a malware problem. The response mindset therefore needs to focus on adversary control, identity and endpoint exposure, backup integrity, logging, containment, and recovery rather than only removing malware.

Key premise

Human-operated ransomware actors may disable or uninstall antivirus, disable security services and logging, and locate, corrupt, or delete backups before making a ransom demand. The field-guide focus is to help teams organize response around those behaviors.

2. At-a-glance response workflow

Step	Phase	Focus
1	Stabilize and declare	Confirm ransomware indicators, activate the incident response process, establish secure communications, and preserve evidence.
2	Scope active control	Identify affected identities, endpoints, servers, backups, security controls, logging gaps, and attacker tools or legitimate tools used maliciously.
3	Deploy investigation telemetry	Use Microsoft security services and available telemetry to collect endpoint, identity, cloud app, email, and infrastructure evidence.
4	Contain adversary reach	Prioritize containment actions that reduce attacker control while minimizing business disruption and preserving recovery paths.
5	Recover critical capability	Validate backup integrity, restore or rebuild critical systems, and bring essential services back in a known secure state.
6	Harden post-incident	Address root causes and control gaps, improve monitoring, reduce attack paths, harden identity and Tier 0, and capture lessons learned.

3. Microsoft security services used in ransomware investigations

The Microsoft Learn article states that Microsoft Incident Response relies heavily on data and uses Microsoft security services across multiple control planes during ransomware investigations.

Service / signal source	Ransomware investigation value
Microsoft Defender for Office 365	Email and collaboration evidence, phishing-related context, payload delivery, user interaction, and campaign investigation where available.
Microsoft Defender for Endpoint	Endpoint detections, behavioral analytics, machine learning, advanced hunting, indicators of compromise, and threat actor behavior across devices.
Microsoft Defender for Identity	Identity-focused signals, domain controller context, lateral movement, and on-premises identity compromise evidence.
Microsoft Defender for Cloud Apps	Cloud app activity, anomaly detections, app usage and SaaS activity, and additional visibility when connected.
Microsoft Sentinel / SIEM	Centralized log visibility, incident correlation, hunting, timeline development, and response automation when configured.
Microsoft Defender XDR	Unified incident investigation, evidence correlation, automated investigation, and response status where applicable.

4. Investigation and response checklist

Incident activation and evidence preservation

- ☐ Confirm ransomware indicators and determine whether the event should be declared as a ransomware incident.
- ☐ Establish a secure collaboration channel that does not rely on potentially compromised infrastructure.
- ☐ Preserve logs, alerts, memory/disk evidence where feasible, attacker artifacts, and affected-system context.
- ☐ Identify business-critical systems, backup dependencies, identity dependencies, and recovery priorities.

Scoping and telemetry collection

- ☐ Identify affected endpoints, servers, identities, privileged accounts, security tools, backups, and cloud services.
- ☐ Review evidence of security control tampering such as antivirus removal, logging disruption, service disablement, or backup deletion.
- ☐ Collect endpoint, identity, email, cloud app, network, SIEM/Sentinel, and Defender XDR evidence where available.
- ☐ Track attacker tools and legitimate administrative tools that may have been abused.

Containment and active adversary control

- ☐ Prioritize containment of accounts, devices, Tier 0 assets, remote access paths, and known attacker infrastructure.
- ☐ Reduce the attacker's ability to re-enter by addressing credentials, persistence, lateral movement paths, and unmanaged endpoints.
- ☐ Avoid actions that destroy evidence or prevent recovery unless required to stop ongoing destructive activity.
- ☐ Maintain a formal decision log for urgent containment choices.

Recovery and restoration

- ☐ Validate backups before restoration and ensure backup systems were not corrupted or deleted by the actor.
- ☐ Restore critical identity, endpoint, and business systems in a controlled order based on business risk.
- ☐ Confirm systems are restored into a known secure state before reconnecting broadly.
- ☐ Monitor restored assets for signs of reinfection, re-entry, or new attacker activity.

Post-incident hardening

- ☐ Document root cause, timeline, attacker path, impacted systems, containment, recovery, and control gaps.
- ☐ Improve identity security, endpoint hygiene, monitoring, logging, backup protection, privileged access controls, and incident response procedures.
- ☐ Conduct an outbrief and convert recommendations into owners, due dates, and measurable completion criteria.

5. Detailed field guidance

5.1 Treat ransomware as an active-adversary incident

- Human-operated ransomware often includes deliberate preparation before encryption or extortion, so responders should look for reconnaissance, privilege escalation, defense evasion, backup targeting, and lateral movement.
- The immediate goal is to understand adversary reach of control and prevent the attacker from continuing destructive or extortion activity.
- Technical recovery should be coordinated with containment so restored systems are not immediately re-compromised.

5.2 Use data-driven investigation across control planes

- Use endpoint, identity, email, cloud app, SIEM, and workload telemetry together rather than relying on a single detection source.
- Build a timeline that links initial access, tool use, credential access, lateral movement, defense evasion, backup impact, ransomware deployment, and recovery actions.
- Map evidence to impacted accounts, devices, servers, workloads, and business processes to guide containment and recovery priorities.

5.3 Contain while preserving recovery options

- Containment should prioritize the attacker's current control paths: privileged identities, remote access, compromised endpoints, known command channels, and abused administrative tools.
- Coordinate with infrastructure and business continuity teams before broad shutdowns or isolation actions where possible, because ransomware recovery often depends on identity, backup, and network services remaining available in a controlled way.
- Use secure communications and a decision log so containment decisions are transparent to executives, legal, IT, and security stakeholders.

5.4 Recover with validation and monitoring

- Validate backups before restoration and ensure recovery does not depend on compromised credentials or compromised management infrastructure.
- Restore critical business capability in a deliberate order, with security validation before broad reconnection.
- Continue monitoring after restoration for evidence of surviving persistence, new lateral movement, repeated credential abuse, or attempted re-encryption.

5.5 Convert the incident into resilience improvements

- Post-incident work should address gaps in backups, identity security, privileged access, system hardening, endpoint coverage, logging, and response readiness.
- Create accountable remediation work items with owners and target outcomes rather than leaving broad recommendations unassigned.
- Use tabletop exercises and lessons learned to improve future coordination between technical teams, business leadership, legal/compliance, communications, and support partners.

6. Evidence and decision matrix

Question	Helpful evidence / decision inputs
----------	------------------------------------

Was this ransomware or pre-ransom activity?	Encryption indicators, ransom note, mass file changes, security tool tampering, backup targeting, suspicious lateral movement, Defender/SIEM incidents
How did the actor gain access?	Identity logs, endpoint timeline, email evidence, RDP/VPN/remote access logs, vulnerable service exposure, attacker tooling
What control did the actor obtain?	Privileged account use, domain/Entra activity, remote sessions, lateral movement events, admin tool abuse, service disablement
Were backups targeted?	Backup system logs, deletion/corruption events, failed restore tests, shadow copy deletion, storage access logs
What must be contained first?	Active command paths, privileged identities, spreader devices, Tier 0 systems, remote access, unmanaged endpoints
What can be restored safely?	Validated backup state, clean identity path, endpoint rebuild status, network segmentation, monitoring coverage
What needs long-term hardening?	Root cause, identity gaps, privileged access controls, backup resilience, endpoint coverage, logging retention, incident readiness

7. Closure notes template

- ☐ Incident summary: ransomware or pre-ransom activity, initial trigger, business impact, and response status.
- ☐ Timeline: first observed access, privilege escalation, defense evasion, backup targeting, encryption/extortion, containment, and recovery milestones.
- ☐ Scope: impacted users, privileged accounts, endpoints, servers, cloud services, backups, and business functions.
- ☐ Evidence reviewed: Microsoft Defender products, Sentinel/SIEM logs, identity logs, endpoint telemetry, backup logs, workload logs, and attacker artifacts.
- ☐ Containment actions: isolated systems, disabled accounts, blocked remote access, rotated credentials, stopped malicious tooling, and protected backups.
- ☐ Recovery actions: restored services, rebuilt systems, validated backups, reinstated monitoring, and verified no known active adversary control remains.
- ☐ Post-incident improvements: identity hardening, backup resilience, endpoint coverage, logging, detection rules, tabletop exercises, and executive outbrief follow-up.

8. Authoritative sources

Primary Microsoft Learn article: [Microsoft Incident Response ransomware approach and best practices | Microsoft Learn](#)

Related Microsoft Learn ransomware hub: [Microsoft defense against ransomware, extortion, and intrusion | Microsoft Learn](#)

Related Microsoft Learn case study: [Microsoft Incident Response ransomware case study | Microsoft Learn](#)

Related Azure response guidance: [Detect and respond to ransomware attacks | Microsoft Learn](#)

This field guide does not replace the official articles. Always reference Microsoft Learn for the latest guidance, product details, and response recommendations.